

TECHNICAL & SECURITY DUE DILIGENCE

RID2Caltopo Public-Service Program

Board technical review of the Android and iOS apps, public websites, and companion r2c-tracker hosted service

Prepared for: Nevada County Sheriff's Search and Rescue Board of Directors and technical reviewers

Purpose: Conditional adoption and stewardship due diligence

Review date: August 8, 2026

Evidence basis: Current source, project documentation, executed security gates, and point-in-time live cloud inspection and hardening

Classification: Board review draft - updated after initial remediation; contains architecture and risk information; distribute deliberately

RECOMMENDATION Continue the limited NCSSAR-controlled pilot. Material source and no-outage cloud controls are now implemented, but adoption and external expansion should remain conditioned on institutional ownership, proven IAP-only host administration, backup/reconstruction evidence, tested monitoring/incident response, independent review, written CalTopo relationship review, and field qualification.

Executive assessment

The program demonstrates a thoughtful security direction and now has a stronger, repeatable assurance baseline for its controlled pilot. In addition to organization-scoped authorization, CSRF protection, OAuth safeguards, revocable device credentials, audit events, private database routing, and explicit operator consent, the published server includes an executable authorization inventory, bounded archive restore, restricted browser CORS, production HSTS, exact dependency resolution, automated vulnerability/static/secret checks, CycloneDX SBOM generation, and fail-closed handling for unconfigured legacy credentials.

The present assurance level remains pilot-grade. Tracker v1.4.24 is live on Cloud Run revision r2c-tracker-pilot-00092-m68 with 100 percent of traffic, and post-deployment checks confirmed its version record, HSTS, rejection of an untrusted CORS preflight, and exclusion of restricted tenants from the public organization directory while direct authenticated access remains available. Both public RID2Caltopo domains render the versioned best-effort acknowledgment, neutral mySAR examples, and an independence statement explaining that RID2Caltopo is not affiliated with or endorsed by CalTopo and uses the CalTopo Teams API. No-outage database-host controls are live, but public SSH and the VM public IP remain until a maintenance-window repair proves IAP access. Board-controlled ownership and recovery identities, alert destinations, backup/restore evidence, an incident tabletop, independent

tenant/cloud review, written CalTopo relationship review, full cross-platform supply-chain coverage, and managed-video field qualification remain open.

The appropriate Board decision remains conditional stewardship: continue the limited NCSSAR-controlled pilot, retain the completed controls, and close or explicitly accept the remaining institutional, host-access, recovery, monitoring, independent-review, external-product/API, and field-qualification risks before broader onboarding or payment.

Review conclusion at a glance

Area	Assessment	Board implication
Security architecture	Improved pilot controls	Retain the new authorization and security gates; independently verify tenant and live-cloud boundaries.
Operational safety	High-consequence, best-effort tool	Maintain no-SLA/no-life-safety-reliance terms and field qualification gates.
Privacy and data	Sensitive operational data is present	Approve inventory, retention, access, export, and incident rules before expansion.
Resilience	Runbooks drafted; recovery unproven	Approve recovery objectives, separate backup custody, and complete a witnessed reconstruction exercise.
Software supply chain	Server gate established; program coverage partial	Retain lock/SBOM/scans and extend them to container, Android, Apple, websites, bundled media, and release provenance.
Adoption readiness	Conditional - improved	Continue controlled pilot; complete remaining P0/P1 institutional and evidence gates before expansion.

1. Scope, method, and limitations

Systems in scope

- RID2Caltopo Android application, including Remote ID processing, local records, CalTopo publishing, tracker coordination, organization configuration, and managed-video client functions.
- RID2Caltopo Apple application and shared R2CCore package, including equivalent configuration, privacy, archive, and coordination behavior.
- RID2Caltopo public websites and the managed-access request form and worker.
- r2c-tracker FastAPI application, organization control plane, enrollment, FAA proxy, flight-log storage, platform administration, and managed-video signaling.
- Pilot deployment documentation for Cloud Run, PostgreSQL, Cloud Storage, Secret Manager, OAuth, Gmail delivery, and network connectivity.

Evidence reviewed

Evidence	Status	Use in this report
r2c-tracker source	Commit fdb993e and release tag v1.4.24	Architecture, auth, tenancy, storage, deployment, tests
RID2Caltopo source	Commit ad18a088 and release tag v2.0.3(125)	Android/iOS data handling, credentials, safety controls
Website source	Commit de3a473; Cloudflare Worker and Sites publications verified	Managed-access acknowledgment and intake enforcement
Automated verification	Tracker 228 tests plus dependency/static/secret/SBOM gate; website 7 rendered tests; Android releaseCheck and Apple package/disclaimer tests passed	Current regression/security evidence; not adversarial or physical field assurance
Tracked-source secret pattern scan	Reviewed baseline enforcement passes; scan artifact retained	Blocks new tracked-source findings; history and independent review remain open
Live Google Cloud inspection	Inspection plus no-outage hardening completed August 7-8, 2026	Deletion protection, web-tag removal, RDP deny, IAP path, and remaining VM/access gaps

ASSURANCE LIMIT This is an engineering due-diligence review with a limited, point-in-time cloud inspection. It is not a penetration test, comprehensive source-code or cloud security audit, legal opinion, privacy impact assessment, aviation certification, or field-safety qualification.

Evidence labels used

- Implemented: observed in current source.
- Tested: exercised by automated tests or release gates identified above.
- Live-observed: read-only configuration evidence obtained on the review date; not proof of historical state, effective runtime behavior, or recovery.
- Documented: described in project documentation but not independently revalidated.
- Open: missing, incomplete, or requiring technical-team confirmation.

2. System architecture and trust boundaries

Current RID2Caltopo Program Trust Boundaries

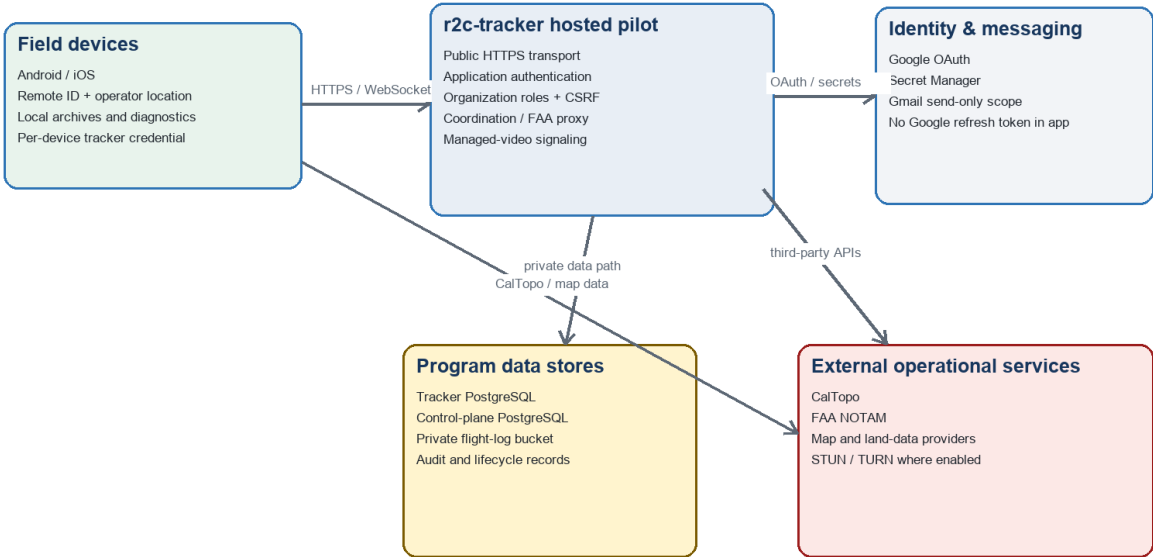


Figure 1. Current logical architecture and principal trust boundaries.

Primary trust boundaries

Boundary	Data crossing	Current control direction
Field device ↔ tracker	Device identity, operator/drone positions, coordination, flight uploads, FAA queries, signaling	HTTPS/WebSocket plus application credential; per-device credentials are hash-stored and revocable.
Browser ↔ organization administration	Member identity, roles, records, exports, video requests	Session cookie, CSRF, role checks, no-store administrative responses, restrictive page CSP.
Platform admin ↔ control plane	Organization lifecycle, contacts, billing metadata, provisioning, audit	Separate super-admin identity; design excludes tenant flight content from platform-admin routes.
Application ↔ data stores	Tracker records, organization metadata, logs, audit state	Separate tracker/control-plane databases; private VM network path; organization namespacing in shared storage.
Program ↔ third parties	OAuth identity, email, FAA query, maps, CalTopo data, STUN/TURN	Scoped integration and server-side secrets, but availability and external terms remain outside program control.

Deployment model observed in source and live configuration

- Cloud Run revision r2c-tracker-pilot-00092-m68 served 100% of traffic from an image digest, using a dedicated runtime service account, one-instance application limit, 1 GiB memory, and Direct VPC egress.
- Cloud Run accepts public HTTPS transport and all ingress so mobile clients can connect; security therefore depends on application authentication and authorization, not network perimeter alone.
- Separate tracker and control-plane PostgreSQL URLs are injected from Secret Manager and currently point through VPC peering to a Compute Engine database VM; no Cloud SQL instance was present in the application project.
- The flight-log bucket enforced public-access prevention and uniform bucket-level access, granted the runtime objectUser, and retained deleted objects for seven days; object versioning was not shown in the live description.
- Application keys and third-party credentials are Secret Manager references; the runtime held per-secret accessor bindings and project-level Cloud SQL client, although Cloud SQL was not currently attached.
- The database VM's PostgreSQL rule continues to allow TCP 5433 only from the Cloud Run subnet, and public probes to PostgreSQL did not connect. Live remediation enabled deletion protection, removed the unused HTTP/HTTPS tags, created a logged public-RDP deny, and added an IAP SSH firewall/IAM path. The VM still has a public IP and public SSH while guest key/OS Login handling awaits a brief controlled restart; Secure Boot, snapshot/restore evidence, and tested monitoring also remain open.

3. Data inventory and privacy significance

The program processes data that may reveal an incident location, agency activity, aircraft identity, personnel identity, or operational tactics. Even when it is not legally regulated personal information, it should be treated as sensitive public-safety operational data.

Data class	Examples	Where handled	Recommended classification
Operational location	Operator coordinates, aircraft tracks, incident/map identifiers	Mobile apps, tracker, archives, CalTopo/FAA queries	Restricted operational
Organization identity	Agency, designator, administrators, member emails and roles	Control plane, browser sessions, email	Confidential
Credentials and capabilities	Device token, CalTopo secret, session/signing keys, OAuth and FAA secrets	Keychain/app storage, Secret Manager, server memory	Secret
Flight records	GeoJSON logs, timestamps, weather, map/incident metadata	Mobile local storage, PostgreSQL, Cloud Storage	Restricted operational

Data class	Examples	Where handled	Recommended classification
Diagnostics	Remote IDs, positions, network addresses, device/OS status	Local device, exported bundles, logs	Restricted operational
Video signaling/metrics	Requester identity, stream metadata, route, consent, byte counts	Control plane and clients	Confidential operational
Video media	Live controller imagery/audio when enabled	Designed for direct or TURN path—not platform recording	Highly restricted; no recording by default
Financial metadata	Usage aggregates, grants/fees if later enabled	Control plane/billing export	Confidential financial

Current privacy-positive controls

- No advertising or cross-app tracking is declared in the mobile privacy materials.
- Apple CalTopo and tracker secrets are stored in Keychain; encrypted iCloud configuration backup separates the passphrase from the backup file.
- Diagnostic bundle sharing requires an operator-selected destination and excludes credential secrets and configuration tokens by design.
- FAA OAuth credentials remain server-side; mobile devices send only the geographic query and tracker credential.
- Managed-video probe payload excludes image, audio, location, flight records, and controller packets; platform design avoids ingesting or recording media.
- Organization archive downloads are intended to require organization-scoped authorization and storage-path confinement.

Privacy actions required

- Approve one authoritative data inventory, classification standard, retention schedule, and deletion/legal-hold process across both mobile platforms, tracker databases, bucket, logs, email, and backups.
- Confirm Android credential-at-rest and backup behavior on supported OS versions; document the difference from Apple Keychain explicitly.
- Define participating agencies as data owners or controllers and NCSSAR as service operator/custodian, subject to counsel review.
- Set access-log and diagnostic retention, review who can read them, and prevent secrets or full operational payloads from entering routine logs.
- Establish lost-device, member-departure, credential-revocation, agency-offboarding, and records-export procedures.

4. Implemented security controls

Control area	Current evidence	Assessment
Administrative authentication	Google authorization-code flow uses state, nonce, PKCE, signed ID-token/audience/issuer checks, verified email, and infrastructure identity matching; fallback passwords use salted scrypt.	Strong pilot direction; require MFA/organizational account policy and live verification.
Session and request protection	HTTPS-only cookie is required in pilot configuration; SameSite=Lax; administrative forms use namespace-scoped CSRF tokens and constant-time comparison.	Implemented; add expiration/session policy review and test every state-changing route.
Browser hardening	Administrative responses use no-store, no-referrer, nosniff, DENY framing, and a restrictive CSP. Browser CORS is restricted to configured origins, methods, and headers; production responses add HSTS.	Implemented in source and tested; independently verify effective edge TLS/HSTS and route coverage after deployment.
Tenant authorization	Organization-role checks, organization filters, scoped storage paths, an authorization matrix, and an executable route/mutation inventory are present; current tests include cross-tenant negative cases and bounded archive restore.	Meaningful logical isolation with regression enforcement; focused independent adversarial review remains required.
Device enrollment	R2C2 QR carries a signed organization/campaign locator; redemption is bounded and returns a revocable per-device credential; only SHA-256 hash is stored.	Improved over shared credentials; one-year lifetime requires policy tightening.
Secret management	Deployment maps secret references; setup scripts avoid command-line disclosure; FAA/OAuth/DB secrets are intended for Secret Manager.	Documented and partially source-enforced; inventory IAM and rotate during transfer.
Network and storage	VPC database routing, subnet-limited PostgreSQL 5433, bucket public-access prevention/uniform access, deletion protection, unused web-tag removal, logged RDP deny, and additive IAP path are confirmed.	Improved live posture; public SSH/IP, guest-access repair, Secure Boot decision, backups, restore, and alerting remain open.
Auditability	Control-plane audit events record lifecycle, credential, and consent-related changes without intended token values.	Good foundation; define immutability, retention, access, alerting, and review cadence.
Managed video consent	Requester role does not start video; operator approval, route/data estimate, and one-viewer session are designed and auditable.	Good safety/privacy design; production media path remains field-qualification gated.

Control area	Current evidence	Assessment
Release verification	Production-Python gate passes 228 tests, dependency audit with no known vulnerabilities, medium/high static analysis, secret-baseline enforcement, and CycloneDX SBOM generation; website rendered tests, Android releaseCheck, Apple package tests, and mobile disclaimer tests pass.	Published release baseline: tracker v1.4.24 is live on revision r2c-tracker-pilot-00092-m68; RID2Caltopo 2.0.3 build 125 is tagged; website commit de3a473, Cloudflare Worker version 8c95a50d-9941-4c06-920c-d9837639df52, and Sites version 16 are published. Independent review, store-distributed physical-device checks, and full cross-platform provenance remain open.

Security-positive design principles to preserve

- Platform administrators manage organizations and service metadata, not tenant flight content.
- Agency administrators control their own member roles and enrollment campaigns.
- A mobile operator—not a remote administrator—must authorize video streaming.
- The hosted service fails unavailable for FAA proxy errors rather than presenting stale data as current success.
- Trials and grace periods do not trigger automatic data destruction; a human contact and export opportunity precede archival or shutdown.
- The applications and service are explicitly supplemental, best-effort tools with no committed life-safety functionality or availability.

5. Priority risk register

Ratings combine likelihood, impact, and the public-safety context. “High” does not mean exploitation is known; it means the Board should require closure or explicit documented acceptance before the indicated expansion step.

ID	Rating	Risk	Required disposition
R-01	HIGH	Critical accounts, billing, recovery, and knowledge remain concentrated in one developer.	Transfer to organizational ownership; designate and exercise backup access.
R-02	HIGH	Pilot tenants share application, databases, and bucket; isolation is logical. A route authorization matrix and executable inventory enforce coverage, and archive restore is resource-bounded, but no independent adversarial review is complete.	Retain the passing gate; complete focused tenant-boundary review and remaining replay/race/fuzz/resource tests before a second external agency.
R-03	MEDIUM	Organization self-service recovery is scoped and tested, and a platform-continuity runbook now exists, but platform backup separation and reconstruction have not been exercised.	Approve objectives, protect recovery material, and complete a witnessed isolated reconstruction.
R-04	MEDIUM	The server uses an exact dependency lock, automated audit/static/secret gates, Dependabot, CycloneDX SBOM, and an Apache 2.0 license; hashes, container/history/license-policy scans, full platform SBOMs, and protected provenance remain open.	Retain the passing server gate and close the remaining cross-platform and release-governance gaps.
R-05	MED-HIGH	Per-device credentials are revocable but issued for up to one year.	Adopt shorter expiry/rotation, revocation SLAs, last-used review, and lost-device procedure.
R-06	MED-HIGH	Sensitive mobile archives and operational configuration live on field devices with platform-specific storage behavior.	Document at-rest controls, backups, MDM/passcode expectations, and remote/lost-device response.
R-07	MEDIUM	Browser CORS is restricted and production HSTS is source-enforced. Live checks confirmed HSTS and rejection of an untrusted preflight without an allow-origin header; independent edge review remains open.	Retain the origin/method/header restriction and HSTS test; independently verify broader production edge behavior, rate limits, and sensitive-route coverage.
R-08	HIGH	No independent penetration test or focused secure-code review has been completed.	Perform scoped review before broad onboarding or accepting payment.
R-09	HIGH IMPACT	Operators could over-rely on incomplete, delayed, unavailable, or incorrect information.	Retain explicit acknowledgments, training, UI status, independent verification, and field qualification.

ID	Rating	Risk	Required disposition
R-10	MEDIUM	CalTopo, FAA, Google, map providers, Cloud Run, database VM, and TURN are external dependencies. Public materials now disclose that RID2Caltopo is independent, is not affiliated with or endorsed by CalTopo, and uses the CalTopo Teams API; direct vendor review remains open.	Document failure modes, status indicators, fallback, vendor terms, and discontinuation plan. Demonstrate the ecosystem to CalTopo founder Matt Jacobs, request written confirmation on name, Teams API use and attribution, retain the response, and disposition any requested changes.
R-11	MED-HIGH	An interim security policy and incident/monitoring runbooks now exist, but they are not Board-approved; alert channels, retention decisions, contact tree, and tabletop evidence are absent.	Approve ownership and policy; configure two responder destinations; test alerts and complete a tabletop.
R-12	MED-HIGH	Managed-video media delivery remains incompletely qualified, especially Apple and routed paths.	Keep disabled or pilot-labeled until direct/TURN, reconnect, thermal, privacy, and data-use tests pass.
R-13	MEDIUM	An interim repository SECURITY.md defines reporting and response targets, and r2c-tracker now carries the program's Apache 2.0 license; ownership confirmation and an NCSSAR-controlled security address remain open.	Confirm organizational stewardship/ownership responsibilities and replace the personal interim contact during adoption.
R-14	MED-HIGH	Deletion protection, web-tag removal, logged public-RDP denial, and an additive IAP path are live. The VM still has public SSH/IP; guest key/OS Login repair, IAP proof, Secure Boot decision, backups, and alerts remain open.	Use a controlled restart to repair/prove IAP, then block public SSH; plan controlled egress/public-IP removal and complete host/backup review.

Risk treatment standard

- Close: implement and verify the required control with retained evidence.
- Mitigate: reduce likelihood or impact and document the residual risk.
- Accept: Board or delegated committee explicitly accepts a time-bound residual risk with an owner and review date.
- Avoid: disable or defer the feature, agency onboarding, payment, or deployment that creates the risk.

6. Detailed treatment priorities

A. Institutional control and administrator continuity

- Create an account inventory covering repositories, domains, app stores, Google Cloud projects, billing, OAuth clients, FAA access, email sender, TURN, monitoring, and backup destinations.

- Move ownership and recovery to NCSSAR-controlled identities; prohibit a volunteer's personal account from being the sole owner or billing guarantor.
- Use phishing-resistant MFA where available, two independent recovery holders, least-privilege roles, quarterly access review, and emergency revocation steps.
- Run a continuity exercise in which the backup administrator deploys, rolls back, rotates a credential, exports data, and restores service without the primary developer.

B. Tenant isolation and application security

- Maintain the new authorization matrix and executable route inventory, which classify organization/platform routes and all state-changing interfaces and fail when a new route lacks a declared access mechanism.
- Retain the passing cross-organization, scoped-storage, credential, archived-organization, role, and bounded archive-restore tests; extend them with independent replay, race, stale-session, fuzzing, and sustained resource-exhaustion cases.
- Independently verify the new archive upload, entry-count, per-log, and expanded-size limits; review public uploads for content validation, filename/path confinement, timeouts, concurrency, and denial-of-service behavior.
- Decide whether logical isolation in a shared database/bucket is acceptable for the controlled pilot or whether separate schemas, databases, buckets, encryption keys, or projects are required.

C. Resilience, backup, and recoverability

- Keep routine flight-record export, deletion, and restoration under organization-owner/records-admin control; the platform administrator should not mediate those decisions.
- Use the new platform-continuity runbook to establish Board-approved recovery objectives consistent with best-effort service - not an implied SLA - for the hosted service, organization accounts/roles, enrollment/revocation state, audit history, and database host.
- Protect platform-level recovery material with separate administrative access, encryption, retention, and resistance to the same credential compromise that could affect production.
- Reconstruct an isolated non-production environment with a backup administrator and record elapsed time, missing state, and required follow-up.

D. Secure software supply chain

- Retain the server's exact production dependency lock and deliberate update process; add cryptographic hashes and immutable base-image/release provenance where practical.
- Retain the generated CycloneDX server SBOM with each release and extend SBOM coverage to Android, Apple, websites, the container base, and bundled MediaMTX artifacts.

- Keep the CI dependency audit, medium/high static analysis, tracked-source secret-baseline enforcement, full tests, Dependabot checks, SBOM, and Apache 2.0 license; add container, secret-history, license-policy, and cross-platform scans with reviewed thresholds.
- Protect release branches/tags, require review for deployment changes, sign or attest artifacts where practical, and document reproducible rollback.

E. Incident response and monitoring

- Approve and institutionalize the new interim security policy and incident-response runbook, replacing the personal contact with an NCSSAR-controlled address and named incident commander, technical responder, agency liaison, legal/privacy liaison, and scribe.
- Implement the detections specified in the new monitoring standard. The cloud project currently has no notification channel, alert policy, or custom log metric; route Critical/High alerts to two separately held NCSSAR-controlled destinations and test delivery.
- Set log retention and access rules; test that credentials, OAuth codes, reset tokens, raw media, and unnecessary precise location do not enter routine logs.
- Tabletop a lost device, compromised administrator, tenant data exposure, database loss, and third-party outage using the new runbook before broad onboarding; retain actions, owners, deadlines, and alert-delivery evidence.

7. Public-safety and managed-video safeguards

SAFETY POSITION Security controls do not convert RID2Caltopo into a certified dispatch, navigation, collision-avoidance, aviation, or life-safety system. Technical reviewers should evaluate whether the interface consistently communicates stale, unavailable, incomplete, and unqualified states.

Best-effort service boundary

- Android and iOS launch gates now state best-effort, as-is, and as-available operation; no express or implied guarantees of suitability, reliability, availability, accuracy, completeness, merchantability, fitness, or non-infringement.
- The r2c-tracker managed-access form carries equivalent versioned terms and rejects unchecked or stale acknowledgments.
- These acknowledgments support informed use but do not replace safe design, training, incident response, insurance, or counsel-approved terms.
- Operator procedures must require independent verification of navigation, airspace, flight safety, communications, and incident-command information.

Managed-video release gate

Capability	Current design/evidence	Required before operational claim
Request authorization	Organization member requires video_requester role; request does not start video.	Negative authorization tests and live role/revocation verification.
Operator consent	Tablet shows requester and link estimate; pilot/VO explicitly chooses Start.	Physical usability test under field workload and interruption.
Preflight	Synthetic encrypted data-channel probe; no media or location in payload.	Direct and routed qualification across representative networks.
Media path	Designed as direct WebRTC or TURN; tracker relays signaling, not recorded media.	Verify packet/media path, TURN configuration, privacy, one-viewer limit, and teardown.
Apple readiness	Documentation states Apple MediaMTX WebRTC remains incomplete/unqualified.	Keep production advertisement disabled until equivalent physical qualification passes.
Data use and indicators	Route, quality, estimated data, and consent state are intended to be visible/audited.	Sustained cellular/thermal/battery test and clear persistent viewer/stop indication.

Operational qualification evidence

- Build/test success must be reported separately from physical-device installation, launch, UI confirmation, flight exercise, and field proof.
- Qualification should include normal, degraded, stale, unavailable, revoked, offline, and third-party-failure states on both Android and Apple.
- Every public capability statement should identify what is implemented, laboratory-tested, physically qualified, or still experimental.

8. Adoption security gates

The following gates convert this review into a closing checklist. The Board may delegate evidence review, but risk acceptance should be traceable to an authorized decision.

Gate	Required evidence	Owner	Decision point
G-01 Asset and account control	Signed inventory; organizational owners/billing; two recovery administrators; MFA and least privilege	Board officer + technical lead	Before final transfer
G-02 Cloud baseline and remediation	PARTIAL: retained inventory and no-outage controls; independently verify and close public SSH/IP, guest access, Secure Boot, backup/restore, logging, and budget findings	Independent cloud reviewer	Before final transfer
G-03 Platform continuity	PARTIAL: reconstruction runbook drafted; backup administrator must restore a non-production baseline and record time/data gaps	Technical administrator + witness	Before final transfer

Gate	Required evidence	Owner	Decision point
G-04 Security governance	PARTIAL: interim SECURITY.md and incident/monitoring runbooks drafted; Board ownership, contacts, retention, alert tests, and tabletop remain	Board program committee	Before final transfer
G-05 Data governance	Approved inventory, retention, export, archive, deletion, hold, and agency responsibility terms	Board + counsel + technical lead	Before external onboarding
G-06 Tenant boundary	PARTIAL: route/query/storage/WebSocket matrix and 228-test gate pass; archive restore is bounded; focused independent adversarial review remains	Independent application reviewer	Before second agency
G-07 Supply chain	PARTIAL: server lock, SBOM, dependency/static/secret gates, Dependabot, and Apache 2.0 license implemented; hashes, container/history/license-policy, cross-platform SBOMs, and protected provenance remain	Primary developer + reviewer	Before broad onboarding
G-08 Credential lifecycle	Device/admin/session expiry, rotation, revocation, lost-device and offboarding runbooks	Security owner	Before second agency
G-09 External assessment	Scoped penetration test or documented independent secure-code/cloud review; findings disposition	Independent assessor	Before payment or broad access
G-10 Field qualification	PARTIAL: Android/Apple/managed-access acknowledgment tests pass; release-build UI, degraded modes, and field evidence remain	Operational test lead	Before each capability claim
G-11 Managed video	Direct/TURN, Apple/Android, reconnect, thermal, privacy, consent, teardown, and data-use qualification	Operational + security leads	Before production video
G-12 Continuity	Backup administrator successfully executes deployment, rollback, rotation, export, and recovery exercises	Board witness	Before primary developer is sole unavailable

Recommended rollout constraints

1. Keep the current NCSSAR environment as a controlled, best-effort pilot while diligence is underway.
2. Do not accept paying organizations or broadly invite outside agencies before ownership, insurance, terms, incident response, platform continuity, and independent technical review are in place.
3. Add one external agency only after the tenant-boundary, credential, data-governance, export, and continuity gates pass; review the pilot before adding another.
4. Enable managed remote video only under its separate field/security qualification gate.

5. Report quarterly to the Board on risks, incidents, availability, support load, costs, backups, access reviews, dependency status, and unresolved single-person dependencies.

9. Technical-team verification plan

A. Source and release integrity

- Identify the exact repositories, branches, commit IDs, submodules/bundled binaries, license status, maintainers, and official release channels.
- Use the checkpointed tracker v1.4.24, RID2Caltopo v2.0.3(125), and website commit de3a473 as the current review baseline; repeat working-tree, dependency, configuration, and evidence reconciliation before any future transfer or production release.
- Re-run server, website, Android, and Apple release gates from a clean checkout using documented toolchains.
- Produce SBOM and vulnerability reports; resolve or explicitly accept findings by severity and exploitability.
- Verify mobile signing keys, app-store ownership, Android package identity, Apple bundle identity, and recovery procedures.

B. Live cloud and identity

- Record Cloud Run revision, image digest, service account, public ingress, concurrency, instance limits, timeouts, environment values, secret references, VPC path, and rollback target.
- Enumerate IAM bindings for projects, runtime account, Secret Manager, bucket, database VM, billing export, Gmail sender, OAuth clients, and deployment identities.
- Confirm public-access prevention, uniform bucket access, object retention/soft delete/versioning, encryption, lifecycle, and audit logs.
- Confirm database firewall, TLS/private route, roles, patching, disk encryption, backup schedule/retention, restore permissions, monitoring, and host hardening.
- Rotate all transferable secrets during ownership change and prove previous holders can no longer administer the system.

C. Adversarial application testing

- Attempt cross-organization access for records, logs, members, enrollment, credentials, streams, exports, archived organizations, and WebSocket messages.
- Exercise login/reset/activation throttling, OAuth replay/state/nonce failures, CSRF, session fixation, stale identity, role removal, and password-reset enumeration.

- Fuzz uploads, archives, configuration imports, FAA parameters, identifiers, and path names; measure resource exhaustion and error behavior.
- Verify security headers, TLS, HSTS, cookie flags, CORS, cache behavior, content type, redirects, and sensitive data in URLs and logs.
- Validate audit completeness and tamper/access controls without logging token values or sensitive payloads unnecessarily.

D. Recovery and incident exercises

- Reconstruct the hosted service and platform state in an isolated target; compare organization accounts/roles, revocations, audit continuity, and database-host configuration without involving routine tenant records administration.
- Simulate compromised device token, organization administrator, platform administrator, deployment identity, FAA credential, and email sender.
- Simulate Cloud Run rollback, database VM outage, storage outage, Google OAuth outage, FAA outage, CalTopo outage, and TURN failure.
- Confirm each scenario produces truthful user status, a safe degraded mode, evidence for response, and an agency communication path.

10. Required deliverables for final adoption

Deliverable	Minimum contents	Acceptance evidence
System inventory	Components, accounts, vendors, owners, data stores, domains, app stores, integrations	Board-designated reviewer signs current inventory
Architecture and data-flow diagram	Trust boundaries, auth, data classes, media path, third parties, admin paths	Matches deployed configuration
Access-control matrix	Actor/role × route/data/action, including WebSocket and archive paths	Negative tests pass
Security baseline	IAM, MFA, secrets, TLS/headers, network, host, DB, bucket, logging, patching	Live export and reviewer notes
Data governance package	Privacy notice, inventory, retention, export, hold, deletion, offboarding	Board/counsel approval
Incident-response plan	Contacts, severity, containment, evidence, notices, vendors, insurer/counsel	Tabletop completed
Platform continuity package	Service/host reconstruction, protected platform state, successor access, discontinuation/export; routine tenant recovery remains self-service	Backup administrator reconstruction exercise passes
Software assurance package	Clean baseline, tests, SBOM, vulnerabilities, licenses, provenance, known gaps	Reviewer accepts disposition

Deliverable	Minimum contents	Acceptance evidence
Operational qualification matrix	Platform-by-platform capabilities and normal/degraded/field evidence	Operational lead approval
Risk acceptance register	Owner, mitigation, residual risk, approver, deadline/review date	Board or delegated committee action

Proposed technical-team finding

UPDATED DRAFT FINDING The reviewed source and applied no-outage cloud controls support continued use as a limited NCSSAR-controlled pilot. The program is materially better prepared for independent review, but should not yet be represented as independently security-assessed, highly available, formally certified, or ready for unrestricted multi-agency production use. Final adoption should follow institutional control, IAP-only host administration, tested monitoring and platform recovery, independent tenant/cloud review, and documented field qualification and residual-risk acceptance.

Appendix A — Evidence references

Primary project materials reviewed:

- r2c-tracker: Apache 2.0 LICENSE; SECURITY.md; dependency/security requirements and secret baseline; security/Dependabot workflows; security and cloud-inventory scripts; authorization, incident, monitoring, continuity, cloud-hardening, and public-safety documents; core application/authentication/integration source; deployment and architecture documentation; tests; and changes.txt.
- RID2Caltopo: LICENSE; NOTICE; PrivacyPolicy.md; Android AppConfig/organization enrollment, tracker coordination, configuration transfer, launch disclaimer, and release checks; Apple PRIVACY.md, PrivacyInfo.xcprivacy, Keychain-backed settings/enrollment, configuration backup, tracker coordination, launch disclaimer, and R2CCore tests.
- RID2Caltopo website: managed-access request component, request worker, and rendered-page tests.
- NCSSAR proposal: Proposal for Adoption and Stewardship of the RID2Caltopo Program, August 7, 2026.

- Google Cloud observations and controlled changes on August 7-8, 2026: Cloud Run service/revision and IAM, runtime secret references and access roles, bucket controls/IAM, VPC routes, Compute Engine VM/disk posture, firewall rules, deletion protection, removal of unused public-web tags, logged RDP denial, and additive IAP access configuration. Post-deployment evidence includes tracker revision r2c-tracker-pilot-00092-m68 at 100 percent traffic, live v1.4.24 release notes, HSTS, untrusted-origin CORS rejection, exclusion of restricted tenants from the public directory, successful direct tenant sign-in routing, and both public RID2Caltopo acknowledgment pages with neutral mySAR examples and CalTopo independence/API language. No secret payloads were accessed.

Repository baseline caveat

The publication baselines are tracker tag v1.4.24, RID2Caltopo tag v2.0.3(125), and website commit de3a473. The hosted website evidence is Cloudflare Worker version 8c95a50d-9941-4c06-920c-d9837639df52 and Sites version 16. These references identify the exact reviewed application source and publication state; this Board package is updated in a follow-up documentation commit after live verification. A final adoption baseline should retain exact source, dependencies, configuration, evidence, vendor correspondence, and rollback targets as signed or otherwise immutable release records.

Open evidence requests

- Independent review of the retained cloud inventory and change history, with disposition of public SSH/IP, guest access, OS/patch/service state, Secure Boot, VM/database/bucket backup and restore, logging, monitoring, and budget findings.
- Domain registrar, app-store, OAuth, FAA, Gmail, TURN, billing, and recovery ownership records.
- Cross-platform and container SBOMs; container, secret-history, and license-policy scans; hash-pinned dependency evidence; protected release provenance; and independent review of the server security-gate results.
- Board-approved monitoring contacts, tested alert delivery to two responders, log access/retention decisions, completed incident tabletop, incident history, support history, and current vulnerability/defect register.
- Platform-by-platform field qualification results and managed-video qualification evidence.

Appendix B — Reviewer sign-off

Role	Name	Finding / exceptions	Date
Technical lead			
Security reviewer			
Cloud/infrastructure reviewer			

Role	Name	Finding / exceptions	Date
Operational/field reviewer			
Board program sponsor			

Reviewer decision: ☐ Accept for controlled pilot ☐ Accept with conditions ☐ Return for remediation
☐ Do not adopt

Conditions or residual risks accepted by authorized decision-maker:
